Lab 5: Static Code Analysis

Hotel Booking System - hotel_booking_system.py

Name	SRN
RISHIT V N S	PES1UG24AM225

1. Objective

In this lab I ran Pylint, Bandit and Flake8 on the hotel booking script given to me, went through the issues each tool reported, and fixed them. After the fixes I ran all three tools again to check that the issues were gone and that the program still worked.

2. Tools Used

Each tool looks at a different part of the code:

Tool	What it checks
Pylint	Code quality and logical errors. Gives a score out of 10.
Bandit	Security issues such as eval, os.system, weak hashing and hardcoded secrets.
Flake8	PEP 8 style such as line length, unused imports and comparison style.

3. Results

These are the results from the first run on the original file and the final run after all the fixes.

Tool	Before	After
Pylint	5.32 / 10	10.00 / 10
Bandit	6 issues (2 High, 1 Medium, 3 Low)	No issues
Flake8	7 issues	No issues

4. Issues Fixed

I fixed the high and medium severity ones first, mostly from Bandit, and then the smaller style issues. Line numbers are from the original file.

#	Issue	Tool	Severity	Line	Fix
1	Shell command injection	Bandit B605	High	58	Replaced with a plain `print()`; no shell needed.
2	Weak hash (MD5)	Bandit B324	High	47	Switched to `hashlib.sha256`.
3	Use of `eval`	Bandit B307 / Pylint W0123	Medium	42	Function now takes a numeric `multiplier` and computes `base_price * float(multiplier)`.
4	Mutable default argument	Pylint W0102	Medium	15	Default changed to `None`, list created inside the function; `main()` passes its own log and prints it.
5	Bare `except` + `pass`	Bandit B110 / Pylint W0702 / Flake8 E722	Medium	26–27	Catch only `KeyError` and return `False`; return `True` on success.
6	Hardcoded secret	Bandit B105	Low	62, 70	Read from `HOTEL_SECRET_KEY` env var; only print whether it is configured, never its value.
7	Insecure random	Bandit B311	Low	51	Use `secrets.randbelow()`.
8	File not closed safely / no encoding	Pylint R1732, W1514	Low	55–57	`with open(filename, "w", encoding="utf-8")`.

#	Issue	Tool	Severity	Line	Fix
9	Non-snake_case function name	Pylint C0103	Low	15	Renamed to `book_room` (call site updated).
10	Unused variable	Pylint W0612 / Flake8 F841	Low	31	Removed.
11	Unused import	Pylint W0611 / Flake8 F401	Low	6	Removed.
12	`== None` comparison	Pylint C0121 / Flake8 E711	Low	32	`is None`.
13	Redundant if/else	Pylint R1703, R1705	Low	34–37	`return not room_inventory[room_num]["is_booked"]`.
14	Old-style % formatting	Pylint C0209	Low	19	Converted to f-string.
15	Line too long	Flake8 E501	Low	19 / 16	Split the condition into two checks.
16	Missing docstrings	Pylint C0116	Low	15, 23, 30, 40, 46, 50, 54, 61	Added docstrings to all functions.
17	No final newline / no main guard	Pylint C0304 / Flake8 W292	Low	73	Added `if __name__ == "__main__":` guard and trailing newline.

5. Commits

I made one commit for the fixes from each tool.

#	Tool	Changes
1	Bandit	Removed eval, os.system, MD5, insecure random, hardcoded secret, try/except/pass
2	Pylint	Renamed function, fixed mutable default, added docstrings, used with/encoding, removed unused variable
3	Flake8	Removed unused import, used 'is None', wrapped long line

6. Conclusion

After the fixes, Pylint gives 10.00/10 (it was 5.32 at the start), and Bandit and Flake8 do not report anything. The program still gives the same output as before. The most serious problems were the eval() and os.system() calls, since both could let someone run their own code, and the mutable default argument, which was an actual bug. Most of the other fixes were small, like removing unused imports and adding docstrings.